DEPARTMENT OF INFORMATION & COMMUNICATION TECHNOLOGY | SEMESTER V (2026-27)

SMART URL FIREWALL: Phishing & Malicious Link Detection Using Finite Automata

Course Code: 24IC301T · Theory of Computation and Compiler Design | Project Type: Academic Defense Poster

CANDIDATE VIVA CREDENTIALS

Student: Practical & Viva Submission

Enrollment: [Your ID] | Div: ICT-V | Mentor: Dept. Faculty

1. PROBLEM STATEMENT & THE PHISHING VECTOR

Deceptive URL structures exploiting RFC 3986 Userinfo authority parsing

THE THREAT LANDSCAPE:

Over 3.4 billion phishing emails are dispatched daily. Attackers obfuscate malicious destinations using deceptive URL syntax that evades standard filters.

RFC 3986 SPECIFICATION ABUSE (THE '@' ATTACK):

Standard URL syntax defines authority as: scheme://[userinfo@]host[:port]

In standard web browsers, text preceding '@' is treated as discardable login credentials, while the network connection routes entirely to the host AFTER '@'.

ILLUSTRATIVE ATTACK PAYLOAD:

http://secure-login.paypal.com@attacker-controlled-c2.ru/auth

- User perceives legit brand: paypal.com
- Actual TCP connection destination: attacker-controlled-c2.ru

WHY TRADITIONAL APPROACHES FAIL:

- Regex Engines: Vulnerable to catastrophic ReDoS (exponential backtracking).
- Machine Learning / LLMs: High latency (>50ms), GPU-heavy, unsuited for line rate.

2. WHY THEORY OF COMPUTATION & COMPILERS?

Direct isomorphism with compiler lexical analysis (Tokenization)

LEXICAL SCANNER ANALOGY IN COMPILERS:

In a compiler frontend, the Lexer scans source code character-by-character to generate atomic tokens (IDs, Keywords) using Deterministic Finite Automata. A Smart URL Firewall acts as an inline network compiler lexer that tokenizes incoming HTTP request URIs before passing them to the application layer.

DETERMINISTIC O(n) TIME COMPLEXITY:

A DFA guarantees strictly linear O(n) execution time where n = URL length. Exactly ONE state transition is evaluated per input character. Zero recursion, zero guessing, and predictable microsecond-level latency suitable for 10Gbps+.

COMPLETE IMMUNITY TO ReDoS ATTACKS:

Nondeterministic Regex engines (PCRE) suffer from exponential backtracking O(2^n) on nested patterns. A minimized DFA guarantees zero backtracking.

HARDWARE & FPGA SYNTHESIZABILITY:

DFA transition matrices translate directly to Read-Only Look-Up Tables (LUTs) in FPGA / ASIC network interface cards for zero-CPU hardware packet dropping.

3. FORMAL MATHEMATICAL 5-TUPLE DEFINITION

Rigorous deterministic definition: M = (Q, Sigma, delta, q0, F)

FORMAL TUPLE: M = (Q, Sigma, delta, q0, F)

1. State Set (Q): |Q| = 6 States
   - q0: Start / Protocol Scanning State
   - q1: Scheme Prefix Ingested ('http' / 'https')
   - q2: Scheme Delimiter Validated ('://')
   - q3: Legitimate Hostname / Domain Parsing [SAFE STATE]
   - q4: Suspicious Delimiter Detected ('@' Encountered)
   - q5: Malicious Host Parsing Trap [FINAL ACCEPTING STATE]
2. Input Alphabet (Sigma): Equivalence Classes
   - p_proto in {'h', 't', 'p', 's'} | d_delim in {':', '/'}
   - c_char in {a-z, A-Z, 0-9, '.', '-', '_'} (Valid authority chars)
   - '@' = The credential-spoof delimiter symbol
   - invalid = Control characters, spaces, illegal null bytes
3. Initial State: q0 in Q
4. Final / Trap State Set: F = { q5 } (Malicious Classifier)
   (Dual-mode: q3 acts as Safe Accept State when verifying cleanliness)

4. 6-STATE DETERMINISTIC FINITE AUTOMATON (DFA) STATE DIAGRAM

Deterministic state transitions for URL validation and '@' credential-spoof detection

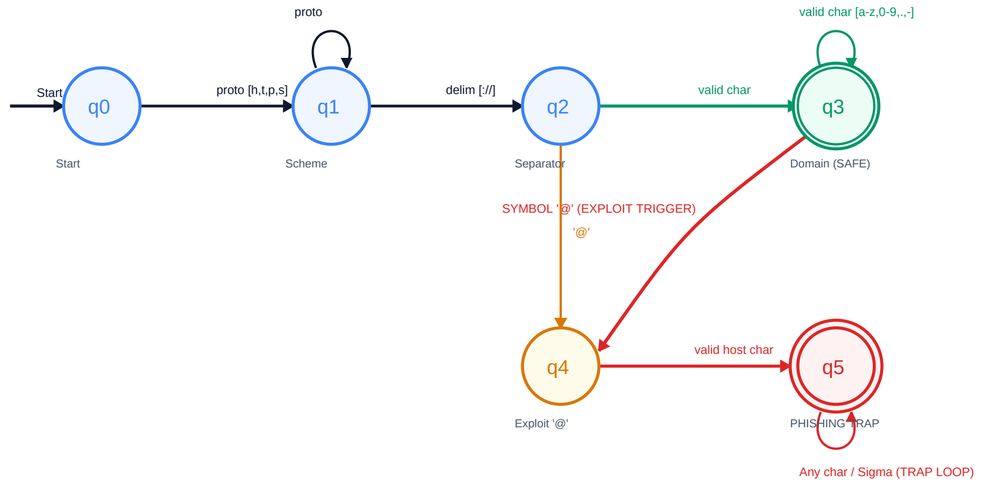


DIAGRAM SEMANTIC LEGEND & VIVA TAKEAWAYS:

[GREEN q3] Safe Host State: If stream ends in q3, URL has clean authority without obfuscation.

[RED q5] Trap Phishing Alert: Double-ring accepting state. Absorbs remaining payload and drops packets instantly.

5. FORMAL STATE TRANSITION TABLE (delta : Q x Sigma -> Q)

Complete matrix representation defining total transition function across all states

State Q	Proto [h,t,p,s]	Delim [://]	Char [a-z,0-9]	Symbol '@'	Invalid	Semantic Classification
-> q0 (Start)	q1	q0	q0	q0	Reject (Trap)	Scanning scheme letters (h,t,p,s)
q1	q1	q2	Reject	Reject	Reject	Protocol prefix matched (http/https)
q2	q3	Reject	q3	q4	Reject	Scheme delimiter verified (://)
* q3 (SAFE)	q3	q3	q3	q4 (ALARM)	Reject	Normal hostname parsing [Valid URL]
q4	q5	q5	q5	q5	Reject	Exploit detected, bridging to host
** q5 (TRAP)	q5	q5	q5	q5	Reject	MALICIOUS PHISHING TRAP [Drop Packet]

KEY PROPERTIES OF THE TRANSITION FUNCTION:

1. Total Determinism: Exactly one target state delta(q, a) exists for every (state, symbol) pair.
2. Trap State Invariance: Once in q5, for any symbol s in Sigma, delta(q5, s) = q5 (Dead/Absorbing state).
3. Rejection Policy: Any illegal byte (e.g., spaces or non-ASCII control characters) routes to Reject state.

6. RUNTIME STRING TRACING & PROOFS

Formal execution traces delta*(q0, w) validating correctness

TRACE 1: LEGITIMATE ENTERPRISE URL (SAFE)

```
Input String w1 = 'https://google.com'
  delta(q0, 'h') = q1   --> delta(q1, 't') = q1 --> delta(q1, 'p') = q1
  delta(q1, 's') = q1   --> delta(q1, '://') = q2
  delta(q2, 'g') = q3   --> delta(q3, 'oogle.com') = q3
Final Evaluated State:  q3 in Q (q3 not in F)
Classification:  SAFE URL -> Traffic Permitted [HTTP 200 OK]
```

TRACE 2: PHISHING CREDENTIAL-SPOOF URL (ATTACK)

```
Input String w2 = 'http://paypal.com@evil-c2.ru'
  delta(q0, 'http') = q1  --> delta(q1, '://') = q2
  delta(q2, 'paypal.com') = q3  (Looks benign so far)
  delta(q3, '@') = q4           *** EXPLOIT TRIGGERED ***
  delta(q4, 'e') = q5           (Target host captured)
  delta(q5, 'vil-c2.ru') = q5   (Trapped in alert state)
Final Evaluated State:  q5 in F (Accepting Threat Trap)
Classification:  MALICIOUS PHISHING -> Traffic Blocked [HTTP 403]
```

7. COMPILER DESIGN BRIDGE: REGEX & CFG

Theoretical connection to Lexical Scanning, Grammars & Chomsy Hierarchy

REGULAR EXPRESSION EQUIVALENCE (KLEENE'S THEOREM):

The suspicious language L_phish recognized by DFA M is defined by:

R_phish = (http | https) :// [a-zA-Z0-9.-]+ @ [a-zA-Z0-9.-]+

Every regular language is accepted by a DFA, establishing mathematical equivalence between lexical regex patterns and state transitions.

CONTEXT-FREE GRAMMAR (CFG) FOR URL STRUCTURE:

S -> Proto '://' Authority Path

Proto -> 'http' | 'https'

Authority -> ValidHost | Userinfo '@' MaliciousHost

Userinfo -> Char Userinfo | Char (Attacker spoofing brand)

MaliciousHost -> Char MaliciousHost | Char

COMPILER FRONTEND TOKEN STREAM:

Lexer outputs tokens: <T_SCHEME, http> <T_SPOOF, paypal.com> <T_EXPLOIT_AT, @> <T_TARGET_HOST, evil-c2.ru>

Parser drops the AST tree upon encountering <T_EXPLOIT_AT>.

8. SYSTEM COMPARISON & ADVANTAGES

Evaluating DFA Firewall against PCRE Regex engines & Deep Learning

Evaluation Metric	Proposed 6-State DFA	PCRE Regex Engine	Deep Learning / ML
Time Complexity	Strictly O(n)	O(2^n) Backtracking	O(k x d) (Matrix Ops)
Processing Speed	> 10 Gbps (Line Rate)	< 500 Mbps (ReDoS Risk)	< 50 Mbps (Latency >50ms)
Memory Footprint	< 64 KB (LUT Array)	Variable Heap Memory	> 500 MB (Model Weights)
ReDoS Exploits	100% Immune	Highly Vulnerable	Not Applicable
Hardware Ready	Direct FPGA / Silicon	Impractical in Hardware	Requires GPU / NPU

INDUSTRIAL APPLICATIONS:

- Envoy / NGINX WAF Filter
- Zero-Trust Email Gateway
- DNS Resolver Pre-Filter
- FPGA Network Ingestion Cards

VIVA VOCE DEFENSE CHEAT SHEET (TOP 3 EXAMINER QUESTIONS):

Q1: Why DFA instead of NFA? -> Ans: DFA guarantees O(n) runtime and exactly one state path with no backtracking or nondeterminism.

Q2: Why is q5 a Trap/Dead state? -> Ans: Once '@' occurs in host syntax, the URL violates RFC 3986 clean authority. It is permanently unsafe. | Q3: How does this link to Compilers? -> Ans: Acts as the Lexical Analysis scanner, converting raw characters into security-classified tokens.